

AI Critique — Member 3 (23127185)

Sinh viên: Mai Thị Kim Duyên — MSSV 23127185 — Branch me lyen

Trong HW06, AI (Claude Code) sai hoặc thiếu ở ba chỗ rõ nhất. Thứ nhất, với FR-09, AI mặc định công thức percent theo thói quen implementation ($total * (1 - discount_value)$) thay vì đọc đúng spec $total * discount_value / 100$; nó cũng không phát hiện điều kiện C3 phải là "lớn hơn hoặc bằng" trong khi SUT dùng $>$, và bỏ sót việc omit `user_id` để bypass C5 (max uses) cùng IDOR khi `user_id` nhận giá trị của người khác. Thứ hai, với FR-17, AI giả định ORM sẽ trả 404 khi xoá id không tồn tại, nên không sinh case "DELETE luôn trả 200"; nó cũng không nối validation FR-17 với FR-09: tạo percent = 1000 thành công thì công thức overflow ở apply-coupon. AI còn nhầm đường dẫn liệt kê coupon (GET `/api/coupons` thay vì `/api/admin/coupons`) và không map lỗi UNIQUE constraint sang 409. Thứ ba, với FR-01, AI bỏ qua email trùng khác case (`Admin@eshop.com` vs `admin@eshop.com`) và crash 500 khi Content-Type không phải JSON.

Nguyên nhân: AI tối ưu theo pattern implementation phổ biến (Express/SQLite) mà nó đã thấy, thay vì coi spec là oracle; nó yếu ở suy luận liên API và trạng thái thay đổi giữa các request; và nó thiên vị happy path.

Bài học: spec phải luôn là oracle; mọi output AI phải bị audit VALID/INVALID/INCOMPLETE bởi người; tách suite sanity (xanh) khỏi discovery (bắt bug theo spec); và case human-added phải đến từ việc mình liệt kê lỗ hổng trước rồi mới nhờ AI formalize — không để AI tự "thêm case" hộ.